

CVSS Analyst Cheat Sheet

Common Vulnerability Scoring System v3.1 • KEV • EPSS • CISA BOD 26-04 — Vulnerability Triage Reference

Date: **August 2026** | Version: **1.0**

August 2026 | CVSS v3.1 + KEV + EPSS

CVSS V3.1 — SEVERITY SCALE OVERVIEW

NONE 0.0	LOW 0.1 – 3.9	MEDIUM 4.0 – 6.9	HIGH 7.0 – 8.9	CRITICAL 9.0 – 10.0
----------	---------------	------------------	----------------	---------------------

CVSS scores range 0.0–10.0. Severity ratings guide initial prioritization but must be combined with KEV and EPSS signals for accurate triage.

01

CVSS v3.1 Base Metric Cheat Sheet

EXPLOITABILITY METRICS

Metric	Abbr.	Values → Score Weight	Key Analyst Question
Attack Vector	AV	Network (N) 0.85 · Adjacent (A) 0.62 · Local (L) 0.55 · Physical (P) 0.20	Where must the attacker be to exploit this?
Attack Complexity	AC	Low (L) 0.77 · High (H) 0.44	Are specialized conditions required?
Privileges Required	PR	None (N) 0.85 · Low (L) 0.62 · High (H) 0.27 [Scope=Changed: None 0.85 / Low 0.68 / High 0.50]	What privilege level does the attacker need?
User Interaction	UI	None (N) 0.85 · Required (R) 0.62	Must a user take action for exploitation?
Scope	S	Unchanged (U) · Changed (C)	Does exploitation cross a privilege boundary?

IMPACT METRICS

Metric	Abbr.	Values → Severity	Description
Confidentiality	C	None (N) · Low (L) · High (H)	Degree of information disclosure to unauthorized parties.
Integrity	I	None (N) · Low (L) · High (H)	Ability to modify data without authorization.
Availability	A	None (N) · Low (L) · High (H)	Impact on access to the affected system or resource.

VECTOR STRING FORMAT — HOW TO READ A CVSS VECTOR

Component	Example Value	Read As
CVSS:3.1	CVSS:3.1	Version prefix — always present
AV:N	Attack Vector = Network	Remotely exploitable over the internet
AC:L	Attack Complexity = Low	No special conditions required
PR:N	Privileges Required = None	Unauthenticated attacker
UI:N	User Interaction = None	No victim action needed
S:U	Scope = Unchanged	Stays within privilege boundary
C:H / I:H / A:H	All Impact = High	Total CIA compromise → Score: 10.0

★ Example Critical CVE Vector String ★

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H → Base Score: 10.0 (CRITICAL)

Network-accessible, no auth, no user interaction, changed scope, full CIA compromise. Patch immediately.

02

Base vs. Temporal vs. Environmental Scoring Comparison

CVSS produces three layered scores. **Base** is universal and published by vendors. **Temporal** adjusts for exploit availability. **Environmental** tailors the score to your specific infrastructure and risk posture.

SCORE LAYER COMPARISON — MASTER REFERENCE TABLE

Attribute	BASE SCORE	TEMPORAL SCORE	ENVIRONMENTAL SCORE
Purpose	Universal severity of the vulnerability as designed	Severity adjusted for current exploit landscape	Severity tailored to YOUR environment & assets
Who Sets It	Vendor / NVD / CERT	Vendor or security community	The consuming organization (YOU)
Changes Over Time	No — intrinsic, static	Yes — as exploits mature, patches release	Yes — as your environment changes
Metrics Included	AV, AC, PR, UI, S, C, I, A	Exploit Code Maturity (E); Remediation Level (RL); Report Confidence (RC)	Modified Base Metrics (MAV, MAC...); Confidentiality / Integrity / Availability Req. (CR / IR / AR)
Score Range	0.0 – 10.0	Always ≤ Base Score	0.0 – 10.0 (can raise or lower Base)
Default / Not Defined	All metrics must be set — no defaults	X (Not Defined) = treated as Base value	X (Not Defined) = treated as Base value

Attribute	BASE SCORE	TEMPORAL SCORE	ENVIRONMENTAL SCORE
Effect on Final Score	Foundation — always present	Reduces score when mitigations exist (e.g., Official Fix lowers RL)	Increases score for critical assets; Decreases for mitigated / isolated systems
Primary Analyst Use	Initial severity triage & SLA setting	Adjust urgency when PoC / exploit is public	Risk-based remediation prioritization
Published / Available At	NVD, vendor advisories, CVE.org	Rarely published; computed internally	Internal CVSS calculators (FIRST, NVD)

TEMPORAL METRIC VALUES — WORST TO BEST

Metric	Abbr.	Values (Worst → Best → Not Defined)
Exploit Code Maturity	E	High (H) → Functional (F) → Proof-of-Concept (P) → Unproven (U) → Not Defined (X)
Remediation Level	RL	Unavailable (U) → Workaround (W) → Temporary Fix (T) → Official Fix (O) → Not Defined (X)
Report Confidence	RC	Confirmed (C) → Reasonable (R) → Unknown (U) → Not Defined (X)

 **Analyst Pro Tips**

- **Never use Base Score alone** for patch prioritization — it ignores real-world exploitation status and your environment.
- **Temporal Score drops** when a vendor releases an Official Fix (RL=O) — re-assess after patch availability is confirmed.
- **Environmental Score is your most powerful lever:** a CVSS 9.8 on an isolated dev box may be lower priority than a CVSS 7.2 on an internet-facing payment server.
- **CVSSv4 (released 2023)** introduces CVSS-B, CVSS-BT, CVSS-BE, CVSS-BTE groupings and a new Supplemental metric group — plan migration roadmap by 2025–2026.

03

Modern Triage Workflow — CVSS + KEV + EPSS + BOD 26-04

SIGNAL DEFINITIONS — FOUR CORE TRIAGE INPUTS

CVSS v3.1 Severity Score 0–10. Measures theoretical impact. Static after publication. Foundation for SLA assignment but insufficient alone.	CISA KEV Known Exploited Vulnerabilities catalog. Binary: In catalog = actively exploited in the wild. 1,200+ entries as of mid-2026. Drives unconditional priority.	EPSS Exploit Prediction Scoring System. 0.0–1.0 probability of exploitation within 30 days. Updated daily by FIRST.org. Key BOD 26-04 automation signal.	CISA BOD 26-04 Binding Operational Directive issued June 10, 2026 — supersedes BOD 22-01 & BOD 19-02. Mandatory remediation SLAs: 3–60 days by scenario.
---	--	--	--

TRIAGE DECISION FLOWCHART — STEP-BY-STEP

Step / Decision	YES Outcome	NO Outcome
 NEW CVE IDENTIFIED	→ Proceed to Step 1: KEV Check	—
STEP 1 KEV CHECK Is CVE in CISA KEV Catalog?	⚡ TIER 1 — BOD SLA: 3–15 days. Patch immediately; verify pre-patch compromise. Alert SOC.	→ Proceed to Step 2: EPSS Check
STEP 2 EPSS CHECK EPSS Score > 0.5?	⚡ TIER 1–2 — BOD SLA: 15–30 days. Fast-track patch; alert SOC; monitor KEV catalog daily.	→ Proceed to Step 3: CVSS Base Score
STEP 3 CVSS BASE Base Score ≥ 7.0?	TIER 2 — BOD SLA: ≤ 30 days. Standard patch cycle; apply compensating controls.	→ Proceed to Step 4: Environmental Context
STEP 4 ENV CONTEXT Asset Critical / Internet-facing?	TIER 2–3 — BOD SLA: ≤ 30–45 days. Risk-adjusted patch with compensating controls; env scoring required.	TIER 4 — BOD SLA: ≤ 60 days. Log and defer; re-assess on KEV / EPSS change.

TIER LEGEND — BOD 26-04 REMEDIATION PRIORITY

⚡ TIER 1 BOD: 3–15 days KEV / Active Exploit	⚡ TIER 2 BOD: ≤ 30 days High EPSS or CVSS ≥ 7	TIER 3 BOD: ≤ 45–60 days Moderate Risk	TIER 4 BOD: ≤ 60 days Low / Deferred
---	--	---	---

03

Triage Decision Matrix — Full Reference

TRIAGE DECISION MATRIX — COMBINED KEV + EPSS + CVSS + ASSET CONTEXT

KEV?	EPSS	CVSS Base	Asset Exposure	Tier	BOD SLA	Required Action
✓ Yes	Any	Any	Internet-facing	TIER 1	3 days	Emergency patch / isolate; verify pre-patch compromise before closing ticket
✓ Yes	Any	Any	Internal	TIER 1	15 days	Patch immediately; check for lateral movement risk; verify compromise
✗ No	> 0.5	≥ 7.0	Internet-facing	TIER 1	15 days	Fast-track patch cycle; alert SOC; monitor KEV catalog daily
✗ No	> 0.5	Any	Internal	TIER 2	30 days	Standard patch cycle; monitor EPSS score daily for escalation

KEV?	EPSS	CVSS Base	Asset Exposure	Tier	BOD SLA	Required Action
X No	0.1 – 0.5	≥ 7.0	Any	TIER 2	30 days	Patch next sprint; apply compensating controls; document rationale
X No	< 0.1	4.0 – 6.9	Critical Asset	TIER 3	45 days	Environmental scoring required; document any deviation from standard SLA
X No	0.1 – 0.5	4.0 – 6.9	Internal	TIER 3	60 days	Queue in sprint; monitor weekly for KEV addition or EPSS escalation
X No	< 0.1	< 4.0	Any	TIER 4	60 days	Log and defer; re-assess if KEV status or EPSS changes

KEY OPERATIONAL RULES — BOD 26-04 COMPLIANCE

KEV = Unconditional Priority Any CVE in the CISA KEV catalog is confirmed actively exploited. BOD 26-04 mandates 3 days (internet-facing) or 15 days (internal). Agencies must verify pre-patch compromise before closing the ticket. No exceptions.	EPSS Thresholds — BOD 26-04 > 0.5 → Near-KEV urgency; BOD SLA: 15 days. 0.1 – 0.5 → Queue next sprint; monitor daily for escalation. < 0.1 → Use CVSS + asset context; BOD floor: 60 days.	Environmental Score & Asset Tagging BOD 26-04 mandates asset tagging: Exposure (public / internal), asset type, org / sub-org. A CVSS 9.8 on an isolated dev box may rank below a CVSS 7.2 on an internet-facing payment gateway. Environmental scoring is required for all Tier 3 decisions.
---	---	--

04

CISA BOD 26-04 — Prioritizing Security Updates Based on Risk

Issued **June 10, 2026** — Binding Operational Directive 26-04 supersedes BOD 19-02 and BOD 22-01, harmonizing vulnerability remediation requirements for all federal executive branch agencies. CISA strongly encourages all organizations to adopt the same risk-based approach. The directive introduces a structured four-factor prioritization model for all vulnerability remediation decisions.

BOD 26-04 — THE 4 PRIORITIZATION FACTORS

#	Factor	Definition	Triage Impact
1	Asset Exposure	Is the vulnerable asset reachable from the public internet? Agencies must tag all assets: Exposure = <i>public</i> or <i>internal</i> .	Internet-facing assets receive shortest SLAs (3 days for KEV). Internal assets receive standard SLAs. Asset tagging is mandatory for all agency-managed systems.
2	KEV Status	Is the CVE listed in the CISA Known Exploited Vulnerabilities Catalog? KEV = confirmed active exploitation in the wild. Binary yes / no determination.	KEV = highest urgency, overriding all other scores. Drives 3-day (public-facing) or 15-day (internal) mandatory remediation SLA per BOD 26-04.
3	Exploit Automation	Is exploitation automated or available as a weaponized tool? Considers EPSS score, public PoC availability, and AI-assisted exploit generation risk.	High automation + public exploit = near-KEV urgency. EPSS > 0.5 is the primary automation signal per BOD 26-04 implementation guidance.

#	Factor	Definition	Triage Impact
4	Post-Exploitation Impact	What is the technical impact if exploitation succeeds? Maps to CVSS CIA impact and Scope. Considers data sensitivity, system criticality, and blast radius.	High impact (C:H / I:H / A:H) escalates tier even at lower CVSS Base. Apply Environmental scoring (CR / IR / AR) for all production assets.

BOD 26-04 — REMEDIATION SLA SCENARIOS (3 TO 60 DAYS)

Scenario	Exposure	KEV?	EPSS / CVSS	Max SLA	Compromise Check?
S1: KEV · Internet-facing	Internet-facing	✓ Yes	Any	3 days	Required before ticket close
S2: KEV · Internal	Internal	✓ Yes	Any	15 days	Required before ticket close
S3: High EPSS · Internet	Internet-facing	✗ No	EPSS > 0.5	15 days	Recommended
S4: High CVSS · Internet	Internet-facing	✗ No	CVSS ≥ 7.0	30 days	Optional
S5: Moderate · Internal	Internal	✗ No	CVSS 4.0 – 6.9	45 days	Not required
S6: Low Risk · Deferred	Any	✗ No	EPSS < 0.1 / CVSS < 4.0	60 days	Not required

BOD 26-04 — PHASE I REQUIRED ACTIONS

 Policy & Procedures • Update agency VM policies to include KEV remediation process • Assign roles & responsibilities for directive execution • Define validation, enforcement & internal tracking procedures • Set internal tracking & reporting requirements • Provide policy copy to CISA upon request	 Asset Management • Continuously identify & tag all internet-facing assets • Tag format: Org Sub-org Exposure (public/internal) Asset Type • Report all assets to CDM Dashboard with full IP addresses • Scan every 7 days via CISA-approved machine-readable format • Attest to exposed IPs / domain names quarterly	 Scanning & Compliance • Maintain Cyber Hygiene scanning access at all times • Attest to exposed IP / domain names quarterly • FedRAMP cloud: coordinate compliance via FedRAMP PMO • Non-FedRAMP cloud: work directly with CSP; document deviations • Automate KEV status reporting via CDM Dashboard
---	---	--

Applicability Note

BOD 26-04 is a compulsory directive for all US federal executive branch departments and agencies per **44 U.S.C. § 3552(b)(1)**. It does not directly apply to contractors unless required by the governing contract, but agencies are directed to review contracts for required modifications. FedRAMP-certified cloud offerings must comply via the FedRAMP PMO. CISA strongly encourages all non-federal partners to adopt the same risk-based remediation approach.

Source: [cisa.gov](https://www.cisa.gov) · BOD 26-04 · June 10, 2026

References & Source Documentation

This reference list documents all primary sources cited throughout this cheat sheet. All URLs were verified as of August 2026. Readers are encouraged to check each source directly for the most current version of any specification, catalog, or directive.

PRIMARY STANDARDS & FRAMEWORKS

Ref#	Source	Description	URL / Access Point
[1]	FIRST — CVSS v3.1 Specification	Common Vulnerability Scoring System version 3.1: Specification Document. The authoritative technical specification defining all Base, Temporal, and Environmental metrics, scoring formulas, and vector string format. Maintained by FIRST.Org, Inc.	https://www.first.org/cvss/specification-document
[2]	FIRST — CVSS v3.1 User Guide	Companion document to the v3.1 specification providing scoring guidance, worked examples, and clarifications for each metric. Recommended reading for all analysts applying CVSS.	https://www.first.org/cvss/user-guide
[3]	FIRST — CVSS v4.0 Specification	Common Vulnerability Scoring System version 4.0. Released October 2023. Introduces CVSS-B, CVSS-BT, CVSS-BE, CVSS-BTE score types and a new Supplemental metric group. Organizations should plan migration from v3.1.	https://www.first.org/cvss/v4.0/specification-document
[4]	FIRST — EPSS (Exploit Prediction Scoring System)	Data-driven machine-learning model estimating the probability that a published CVE will be exploited in the wild within the next 30 days. Scores (0.0–1.0) and percentile rankings published daily for every CVE. Freely accessible via CSV and API. Maintained by the EPSS Special Interest Group at FIRST.	https://www.first.org/epss
[5]	EPSS — API & Daily Data Downloads	Direct access to EPSS scores via REST API and daily CSV downloads. Includes historical scores and integration examples for SIEM/SOAR platforms.	https://api.first.org/data/v1/epss

CISA DIRECTIVES & CATALOGS

Ref#	Source	Description	URL / Access Point
[6]	CISA BOD 26-04	Binding Operational Directive 26-04: Prioritizing Security Updates Based on Risk. June 10, 2026. Supersedes BOD 19-02 and BOD 22-01. Establishes mandatory vulnerability remediation SLAs of 3–60 days for all federal executive branch agencies based on asset exposure, KEV status, exploit automation, and post-exploitation impact.	https://www.cisa.gov/binding-operational-directives/bod-26-04
[7]	CISA BOD 26-04 Implementation Guidance	Companion implementation guidance released June 10, 2026 alongside BOD 26-04. Provides detailed procedures, asset tagging requirements, scanning	https://www.cisa.gov/news-events/directives

Ref#	Source	Description	URL / Access Point
		cadence, CDM Dashboard reporting, and FedRAMP compliance paths.	
[8]	CISA KEV Catalog	Known Exploited Vulnerabilities Catalog. Continuously updated list of CVEs confirmed as actively exploited in the wild. Originally established under BOD 22-01. As of mid-2026, contains 1,200+ entries. Federal agencies required to remediate KEV entries within BOD 26-04 SLA timelines.	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
[9]	CISA KEV — JSON/CSV Feed	Machine-readable KEV catalog feed for integration into vulnerability management platforms, SIEMs, and automated triage pipelines. Updated continuously.	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
[10]	CISA BOD 22-01 (Superseded)	Binding Operational Directive 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities. Issued November 3, 2021. Established the KEV catalog and original 2-week/6-month remediation timelines. Superseded in full by BOD 26-04 as of June 10, 2026. Retained for historical reference.	https://www.cisa.gov/binding-operational-directives/bod-22-01
[11]	CISA BOD 19-02 (Superseded)	Binding Operational Directive 19-02: Vulnerability Remediation Requirements for Internet-Accessible Systems. Issued April 29, 2019. Established the original 15-day/30-day remediation timelines for Critical/High internet-facing vulnerabilities. Superseded in full by BOD 26-04. Retained for historical reference.	https://www.cisa.gov/binding-operational-directives/bod-19-02
[12]	CISA Cybersecurity Directives Index	Complete listing of all active and archived CISA Binding Operational Directives and Emergency Directives, with status and issue dates.	https://www.cisa.gov/news-events/directives

VULNERABILITY DATABASES & REFERENCE SOURCES

Ref#	Source	Description	URL / Access Point
[13]	NVD — National Vulnerability Database	NIST's National Vulnerability Database. Primary repository for CVE enrichment data including CVSS Base Scores, CWE mappings, CPE applicability, and reference links. Official source for NVD-published CVSS scores.	https://nvd.nist.gov
[14]	NVD — CVSS Calculator v3.1	Interactive web calculator for computing CVSS v3.1 Base, Temporal, and Environmental scores. Useful for validating vector strings and computing modified scores for environmental assessment.	https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator
[15]	CVE.org	The official CVE Program website, maintained by MITRE with support from the CVE Program Partners. Primary source for CVE ID assignments, descriptions, and reference lists. Replaces legacy cve.mitre.org as canonical CVE reference.	https://www.cve.org
[16]	MITRE CWE — Common Weakness Enumeration	Categorized list of software and hardware weaknesses. Referenced in NVD entries alongside CVSS scores. Useful for root-cause analysis and	https://cwe.mitre.org

Ref#	Source	Description	URL / Access Point
		secure coding guidance. Complementary to CVSS-based severity scoring.	

 **Document Maintenance Note** — This cheat sheet and its references should be reviewed quarterly or whenever a new CISA directive, CVSS version update, or major EPSS model revision is published. The KEV catalog is updated continuously — integrate live KEV feeds into your vulnerability management platform rather than relying on a static snapshot. Contact: **CyberDirectives@cisa.dhs.gov** for BOD compliance questions.